252IS032

40 copies

CS 850 DATABASE SECURITY
II SEM M.TECH (CSE-IS)
MIDSEM EXAM- 23 Feb 2026

Note: Answer ALL Questions **Max.Marks: 50 Marks**

Q1. The CSE department has decided to develop a new electronic grading system. Here are the key features the department wants the system to handle (do not assume any permissions or restrictions other than those explicitly mentioned): (15)

- Each course has some course instructors (CIs) and teaching assistants (TAs) assigned to it.
- TAs and CIs for a given course can both read and write that course's grades; in addition, a course's CI(s) can submit final grades.
- All faculty members can read the grades for every course.
- Graduate students and faculty are disjoint groups.
- No graduate student can be a TA for more than two courses.
- No graduate student can be a Course instructor for any course.
- Faculty members can be teaching assistants or Course instructors for any course, and there are no limits on how they are assigned to courses. (Yes, they may even serve as both the TA and the CI for the same course; I mention this only to make your task easier.)
- Because of the potential for confusion with final grades—especially if instructors have the same students in multiple courses—the electronic grading system must not permit anyone to perform in more than one Course-instructor role at any given time (e.g., login session).

As part of the system's initial test run, the department wants to configure the system to handle just three of the department's courses: CSE 123, CSE 456, and CSE 789. Thus, the department has identified the following roles and permissions for this system:

R = {Fac Grad, 123TA, 123CI , 456TA, 456CI , 789TA, 789CI }
P = {read 123, write123, submit 123, read 456, write456, submit 456, read 789, write789, submit 789}

For example, read 123, write123, and submit 123 are the permissions to (respectively) read, write, and submit the grades for CS 123.

Provide the following RBAC components to accurately meet and fulfill all of the department's desired features/criteria:

i. A role-hierarchy relation and a permission- assignment relation
ii. A static separation-of-duty relation to capture necessary static constraints
iii. A dynamic separation-of-duty relation to capture necessary dynamic constraints

Q2. Suppose you are the database administrator setting up security mechanisms for the Video Stores database (15)

FILM (FNUM, TITLE, OPENED, LENGTH, BUDGET, DIRECTOR, SNUM, RATING, WRITER)
ACTOR (ANUM, FNAME, LNAME, BDATE, GENDER)
ROLES (FNUM, ANUM, PART, SALARY)
STUDIO (SNUM, NAME, ADDRESS, WEBSITE)
ITEM (INUM, FNUM, PRICE, RELEASE, FORMAT, BONUS, INVENTORY)
SHOPPER (SHNUM, FNAME, LNAME, SHIPADDR, CRCARD)
CART (SHNUM, INUM, QUANTITY)

Suppose that the database has the following users:

i. SPIELBERG works in the purchasing department.
ii. SHYAMALN is in the shipping department.
iii. MARSHALL is the manager of the customer service department.

Provide the SQL commands to grant appropriate access privileges and grant propagation privileges. Explain your choices based on how each user will be expected to use the database. If you make any assumptions about these types of users, be sure to explain them.

Q3. a) Describe a scenario in which mandatory access controls prevent a breach of security that cannot be prevented through discretionary controls. (5)

b) In a medical information system that controls access to patient records and prescriptions, doctors may read and write patient records and prescriptions, nurses may read and write prescriptions only but should learn nothing about the contents of patient records. (10)

i. How can you capture this policy in a lattice model that prevents information flow from patient records to prescriptions?
ii. In your opinion, which security model is most appropriate for this policy? (Why?) Sketch a security model capturing the requirement.
iii. A doctor should not be allowed to make a prescription for herself. How can you augment your model above to prevent this kind of prescription abuse?

c) Assume that a database table named Students (SID, SNAME, DEPTID, LOANAMOUNT). Possible queries are COUNT, SUM and MEAN. The database does not reveal results when a small or large number of people are covered by the query. In our database it has been decided that 4-7 people must be covered by the query. We want to find a sequence of queries that tells us the size of Erika's loan. The obvious query SELECT SUM(Loan) FROM Students WHERE name = 'Erika' will not work because the result, 1, is not in the range 4-7. The query will be ignored. Find a general tracker and a sequence of queries that will give you the information. You are allowed to do 4 queries. (5 Marks)

---Good luck---

HO copies

CS850 Database Security – Quiz-1

Q1. Given this HTML and PHD code,

HTML:

```
<form action="sql.php" method="POST"/>
  <p>Username: <input type="text" name="login" /><br />
     Password: <input type="text" value="password" /></p>
</form>
```

PHP:

```
<?php $query = "SELECT * FROM users WHERE username = '{$_POST['login']} AND
      password= '{$_POST['password']}'";  $result = mysql_query($query); echo "$_POST['login'] attempted"}>
```

Assume that logins are allowed if $result above is simply checked as being non-empty.

1. Given this PHP code, give a username and password that will allow you to login without knowing the password.
2. Give a username and password that allows you to login without knowing a valid username.
3. Give a username and password that allows a cross-site scripting attack.

Q2. For example, consider the following simplified prepared statement API:

void executePreparedStmt(String template, ...);

A prepared statement template may have placeholders $1, $2, etc., and a programmer can execute a prepared statement by doing, e.g.

executePreparedStmt("SELECT * FROM users WHERE name = $1 AND passwd = $2", username, pwd);

Write a simple function (at most 5 lines of code) that uses the above prepared statement API but is still vulnerable to SQL injection attacks.

Q3. An application allows users to self-register by specifying their username and password. Every user is assigned a privilege level of 5 by default, which is the lowest privilege level. The query that inserts the data of newly registered users into the database is:

INSERT INTO users (username, password, privilege) VALUES ('Paul', 'Secret',5);

Suggest an input that can elevate a new user's privilege level to 0, which is the highest. Your answer should clearly mention the input supplied to the username and password fields, as well as how the supplied input modifies the internal query.

Q4. A company has deployed a hand-made defense mechanism against SQL injection which removes any SQL keywords it recognizes in the input string. For example, an input designed to launch a piggybacked query in the search field:

Books'; DROP TABLE users;
Gets reduced to:
Books'; TABLE users;
Which makes no sense and cannot launch an attack at the database site.

Suggest a modification of the input which can accomplish the same objective, which is to drop the user table.